

norm

NEN-EN 40000-1-1

Cybersecurity requirements for products
with digital elements - Vocabulary

Publicatie uitsluitend voor commentaar

oktober 2025
ICS 01.040.35; 35.030

Commentaar vóór 2025-12-01

Als Europees normontwerp is gepubliceerd: prEN 40000-1-1:2025,IDT

Definitief vastgestelde normen zullen als Nederlandse norm gelden. Daarom wordt dit normontwerp in Nederland voor commentaar gepubliceerd. Op het ontwerp ingebracht commentaar zal aan de bevoegde normcommissie worden voorgelegd die hiermee rekening zal houden bij de bepaling van de Nederlandse stem. Indien er geen bezwaar bij NEN wordt gebracht, kan dat leiden tot ongewijzigde definitieve vaststelling van het ontwerp als norm.

Van Europese normen bestaan drie officiële versies: Engels, Frans en Duits. Voor Nederland zal de Engelse versie gelden. Daarnaast kan er gekozen worden voor een andere geautoriseerde versie in het Nederlands.

Normcommissie 381027 'Cybersecurity & Privacy'



THIS PUBLICATION IS COPYRIGHT PROTECTED

DEZE PUBLICATIE IS AUTEURSRECHTELIJK BESCHERMD

Apart from exceptions provided by the law, nothing from this publication may be duplicated and/or published by means of photocopy, microfilm, storage in computer files or otherwise, which also applies to full or partial processing, without the written consent of Stichting Koninklijk Nederlands Normalisatie Instituut.

Stichting Koninklijk Nederlands Normalisatie Instituut shall, with the exclusion of any other beneficiary, collect payments owed by third parties for duplication and/or act in and out of law, where this authority is not transferred or falls by right to Stichting Reprerecht.

Auteursrecht voorbehouden. Behoudens uitzondering door de wet gesteld mag zonder schriftelijke toestemming van Stichting Koninklijk Nederlands Normalisatie Instituut niets uit deze uitgave worden verveelvoudigd en/of openbaar gemaakt door middel van fotokopie, microfilm, opslag in computerbestanden of anderszins, hetgeen ook van toepassing is op gehele of gedeeltelijke bewerking.

Stichting Koninklijk Nederlands Normalisatie Instituut is met uitsluiting van ieder ander gerechtigd de door derden verschuldigde vergoedingen voor verveelvoudiging te innen en/of daartoe in en buiten rechte op te treden, voor zover deze bevoegdheid niet is overgedragen c.q. rechtens toekomt aan Stichting Reprerecht.

Although the utmost care has been taken with this publication, errors and omissions cannot be entirely excluded. Stichting Koninklijk Nederlands Normalisatie Instituut and/or the members of the committees therefore accept no liability, not even for direct or indirect damage, occurring due to or in relation with the application of publications issued by Stichting Koninklijk Nederlands Normalisatie Instituut.

Hoewel bij deze uitgave de uiterste zorg is nagestreefd, kunnen fouten en onvolledigheden niet geheel worden uitgesloten. Stichting Koninklijk Nederlands Normalisatie Instituut en/of de leden van de commissies aanvaarden derhalve geen enkele aansprakelijkheid, ook niet voor directe of indirecte schade, ontstaan door of verband houdend met toepassing van door Stichting Koninklijk Nederlands Normalisatie Instituut gepubliceerde uitgaven.

Ontwerp
Draft

EUROPEAN STANDARD
NORME EUROPÉENNE
EUROPÄISCHE NORM

DRAFT
prEN 40000-1-1

October 2025

ICS 01.040.35; 35.030

English version

Cybersecurity requirements for products with digital elements - Vocabulary

This draft European Standard is submitted to CEN members for enquiry. It has been drawn up by the Technical Committee CEN/CLC/JTC 13.

If this draft becomes a European Standard, CEN and CENELEC members are bound to comply with the CEN/CENELEC Internal Regulations which stipulate the conditions for giving this European Standard the status of a national standard without any alteration.

This draft European Standard was established by CEN and CENELEC in three official versions (English, French, German). A version in any other language made by translation under the responsibility of a CEN and CENELEC member into its own language and notified to the CEN-CENELEC Management Centre has the same status as the official versions.

CEN and CENELEC members are the national standards bodies and national electrotechnical committees of Austria, Belgium, Bulgaria, Croatia, Cyprus, Czech Republic, Denmark, Estonia, Finland, France, Germany, Greece, Hungary, Iceland, Ireland, Italy, Latvia, Lithuania, Luxembourg, Malta, Netherlands, Norway, Poland, Portugal, Republic of North Macedonia, Romania, Serbia, Slovakia, Slovenia, Spain, Sweden, Switzerland, Türkiye and United Kingdom.

Recipients of this draft are invited to submit, with their comments, notification of any relevant patent rights of which they are aware and to provide supporting documentation. Recipients of this draft are invited to submit, with their comments, notification of any relevant patent rights of which they are aware and to provide supporting documentation.

Warning : This document is not a European Standard. It is distributed for review and comments. It is subject to change without notice and shall not be referred to as a European Standard.



CEN-CENELEC Management Centre:
Rue de la Science 23, B-1040 Brussels

Contents		Page
European foreword		3
Introduction		4
1	Scope	5
2	Normative references	5
3	Terms and definitions	5
Bibliography		8

Ontwerp
Draft

European foreword

This document (prEN 40000-1-1:2025) has been prepared by Technical Committee CEN/CLC/JTC 13 "Cybersecurity and Data Protection", the secretariat of which is held by DIN.

This document is currently submitted to the CEN Enquiry.

This document has been prepared under a standardization request addressed to CEN by the European Commission. The Standing Committee of the EFTA States subsequently approves these requests for its Member States.

Ontwerp
Draft

prEN 40000-1-1 (E)**Introduction**

The effective implementation of cybersecurity requirements for products with digital elements relies on a clear and unified understanding of key concepts. This document provides the common language necessary to ensure alignment and consistency across the corresponding family of European standards.

Ontwerp
Draft

1 Scope

This document provides the terms and definitions commonly used in the cybersecurity requirements for products with digital elements family of standards.

2 Normative references

There are no normative references in this document.

3 Terms and definitions

For the purposes of this document, the terms and definitions given in the relevant Regulation (EU) 2024/2847 and the following apply.

ISO and IEC maintain terminology databases for use in standardization at the following addresses:

- ISO Online browsing platform: available at <http://www.iso.org/obp>
- IEC Electropedia: available at <http://www.electropedia.org/>

3.1

acceptable risk

risk that for the intended and reasonably foreseeable use of the product with digital elements is acceptable from the perspective of the risk acceptance criteria, accounting for the generally acknowledged state of the art, health and safety of the user and other *security objectives* (3.15)

3.2

activity

set of cohesive tasks

[SOURCE: [ISO/IEC/IEEE 12207:2017 \[1\]](#), 3.1.3, modified – "of a process" has been removed]

3.3

advisory

document or message that provides vulnerability information intended to reduce risk

Note 1 to entry: An advisory is meant to inform users or other stakeholders about a vulnerability including, if possible, how to identify and remediate vulnerable systems.

[SOURCE: [ISO/IEC 29147:2018 \[2\]](#), 3.8]

3.4

asset

anything that has value to an individual, an organization or a government

[SOURCE: [ISO/IEC 27035-3:2020 \[3\]](#), 3.1]

3.5

authenticity

property that an entity is what it claims to be

[SOURCE: [ISO/IEC 27000:2018 \[4\]](#), 3.6]

3.6

availability

property of being accessible and usable on demand by an authorized entity

[SOURCE: [ISO/IEC 27000:2018 \[4\]](#), 3.7]

prEN 40000-1-1 (E)**3.7****confidentiality**

property that information is not made available or disclosed to unauthorized individuals, entities, or processes

[SOURCE: [ISO/IEC 27000:2018 \[4\]](#), 3.10]

3.8**integrity**

property of accuracy and completeness

[SOURCE: [ISO/IEC 27000:2018 \[4\]](#), 3.36]

3.9**likelihood**

ease or difficulty with which a security threat scenario could progress to become an incident

[SOURCE: [ISO 28001:2007 \[5\]](#), 3.13, modified – "security incident" changed to "incident" for consistency]

3.10**online hosting location**

infrastructure that stores and serves the resources for a website, application, or online service

3.11**product control**

measure on a product that is modifying risk

3.12**remediation**

change made to a product or service to remove or mitigate a vulnerability

Note 1 to entry: A remediation typically takes the form of a binary file replacement, configuration change, or source code patch and recompile. Different terms used for "remediation" include patch, fix, update, hotfix, and upgrade. Mitigations are also called workarounds or countermeasures.

[SOURCE: [ISO/IEC 29147:2018 \[2\]](#), 3.7]

3.13**reporter**

individual or organization that notifies a vendor or coordinator of a potential vulnerability

Note 1 to entry: There are no special preconditions for acting as a reporter. Reporters can be individuals, organizations, amateurs or hobbyists, professionals, end-users, security research organizations, vendors, governments, or coordinators

[SOURCE: [ISO/IEC 29147:2018 \[2\]](#), 3.5]

3.14**residual cybersecurity risk****residual risk**

cybersecurity risk remaining after risk treatment

[SOURCE: [ISO/IEC 27000:2018 \[4\]](#), 3.57]

3.15**security objective****cybersecurity objective**

result to be achieved concerning the protection from cyber threats

3.16

software package

bundled collection of software and data

Ontwerp
Draft

Bibliography

- [1] ISO/IEC/IEEE 12207:2017, *Systems and software engineering — Software life cycle processes*
- [2] ISO/IEC 29147:2018, *Information technology — Security techniques — Vulnerability disclosure*
- [3] ISO/IEC 27035-3:2020, *Information technology — Information security incident management — Part 3: Guidelines for ICT incident response operations*
- [4] ISO/IEC 27000:2018, *Information technology — Security techniques — Information security management systems — Overview and vocabulary*
- [5] ISO 28001:2007, *Security management systems for the supply chain — Best practices for implementing supply chain security, assessments and plans — Requirements and guidance*

Ontwerp
Draft

Why do you have to pay for a standard?

Standards are agreements for and by the market. They are agreements about matters that concern everyone, e.g. about healthcare, financial services, safety and corporate social responsibility. Life would be a lot more complex without these agreements. Standards improve products, services and processes in the workplace, in our interactions with each other, and in society as a whole.

The agreements are made by interested parties. An interested party can be a producer, entrepreneur, service provider or user, but it can also be a government authority, a consumer association or a research organization. Broad support is important. The agreements are made with support from NEN, and they must not conflict with any other valid NEN standards.

NEN is a non-profit foundation. The services provided by NEN – from bringing parties together and making and recording the agreements, to providing assistance when applying the standards – cost money. That is why all the participating parties pay for the standardization process and you, as a user, pay for the standards, training courses and other products.

Ontwerp
Draft

Ontwerp
Draft